

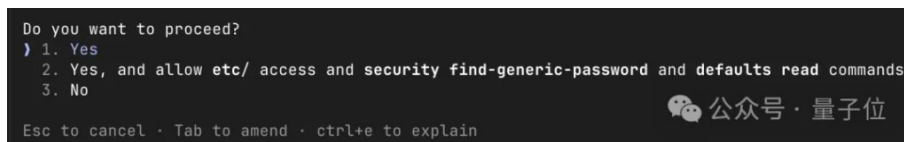
摘要：

5天后，Claude Code将默认启用自动模式，该模式额外消耗的token费用由Anthropic承担。此举是因为人工审批已流于形式（同意率高达97%），而实验证明，自动模式拦截危险命令的成功率（89%）远超人类（13.6%），安全性大幅提升。用户仍可快捷切换回手动模式。

咱就是想问，还有人认真看AI编程工具给的权限审批请求吗？

Anthropic也发现了，只有3%的权限请求被拒绝。

于是他们做了一个决定，5天后，所有Claude Code将默认启用自动模式。



自动模式的分类器每次工具调用会额外消耗少量token，这部分开销将不再向用户收费。

亚马逊谷歌微软等云平台目前仍然是选配，但Anthropic只给他们一个月时间，要把这些渠道也切成默认自动模式。

Claude Code之父表示，团队内部早就只是用自动模式了，根本无法想象再去手动审批权限。



人工审批权限的时代一去不复返

对于这次改动Anthropic给出的第一组理由，是人工审批已经变成一种习惯性动作：

用户对Claude Code权限提示的同意率是97%。作为对照，当Claude把一份计划交给用户批准时，拒绝率是39%；而单条权限请求的拒绝率只有3%。

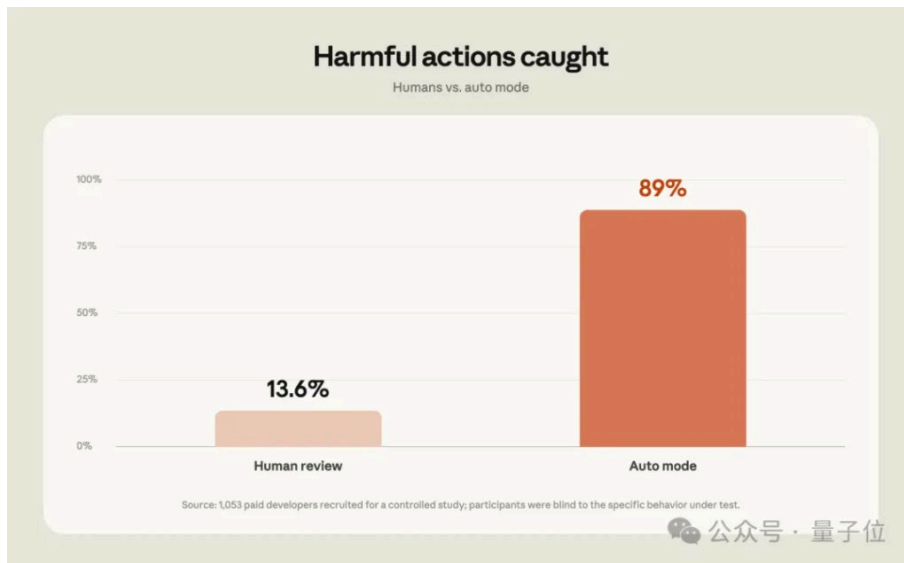
同样的倾向也出现在配置文件里。截至2026年6月，49.5%的活跃CLI用户手动写过Bash allow-rule，其中5%直接放行任意shell命令，另有43%写了Bash(python:)、Bash(node:)这类实际效果基本等同的解释器规则，这个比例大约每周五周增长5个百分点。

此外，62%的用户用过bypassPermissions或者在Bash上点过“不再询问”，25%的交互式会话一开始就运行在bypass permissions模式下。

第二组理由来自一项受控实验。Anthropic通过研究供应商招募了1053名付费专业测试者，在专门搭建的测试环境里完成编码任务。会话进行到一半时，其中一条权限提示被替换成一条明显危险的命令，供应商记录测试者是否点了同意（同意并不会真的执行任何危险操作，被改动的只是提示文本）。

结果是测试者拦住这条命令的比例为13.6%，143次；
auto mode面对同样的命令拦下了89%，937次。

正面比较下来，auto mode拦住了800条人类放行的命令，人类只拦住了6条auto mode放行的命令。



而且会话越长，人的表现越差：前期还能拦住约17%，在经历50条以上提示之后降到约5%，而 auto mode的拦截率不随会话长度变化。

生产数据也被拿来重新打分。

2026年5月到6月，Anthropic从已授权数据用于训练与分析的账号中，取出安全流水线标记过的会话，用模型按0到10的严重程度重新评级。

- 10分代表全公司范围、不可逆的伤害。
- 7分代表删除生产数据库记录这一级别
- 0分代表覆盖一个临时文件这类完全可回滚的本地操作，

同时评估用户对该操作的要求有多明确。在7分及以上的严重级别上，走人工审批的会话中有6.3%出现了用户并未明确要求的有害操作，auto mode会话是2.4%，在测试过的每个严重级别上差距都成立。

分类器本身也经过对抗测试。Anthropic与AI安全公司Apollo Research做了为期两周的试点，把合成攻击注入真实编码轨迹，覆盖泛化失效、数据外泄和安全相关威胁三类数据集。

Apollo交回成功攻击样本与加固建议后，Anthropic主要通过给分类器提供更多环境上下文来加固，包括仓库可见性、git状态和数据处理规则。

加固后Apollo用一组Anthropic无法接触的留出攻击集重测，auto mode追回了此前漏掉的约一半攻击，代价是漏掉约2%此前拦住的攻击，两组数据集合并计算，漏检率从12%降到7%。

Anthropic同时说明，这些攻击是为找出分类器失效点而合成的，7%不应被理解为真实流量下的漏检率。

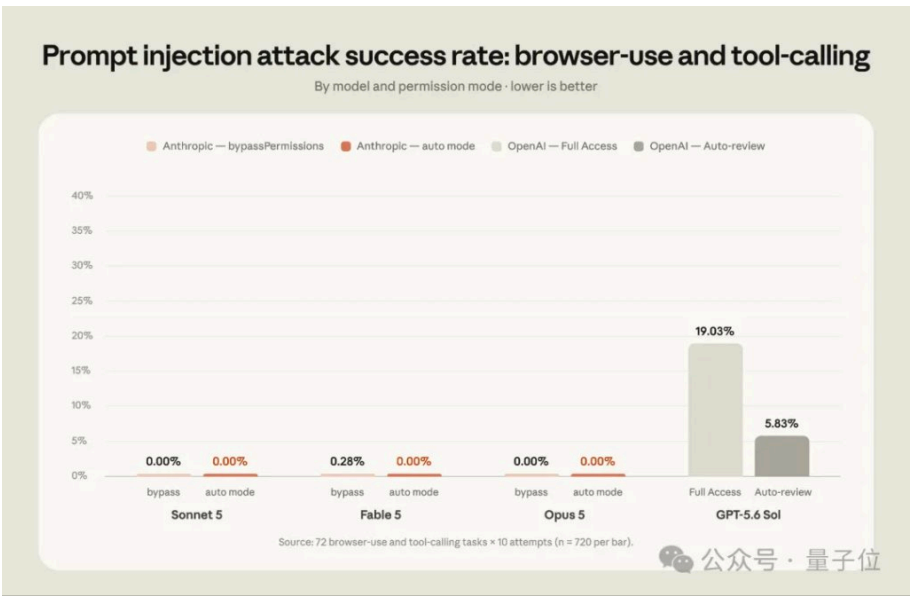
针对提示词注入，Anthropic委托第三方Trajectory Labs做了评测，还拉来了OpenAI来当垫背，共72个间接注入场景，每个场景跑10次。

攻击是针对Claude Opus 4.7优化的，而Opus 4.7不在被测名单中，所以所有参测模型面对的都是未见过的攻击。

在720次攻击尝试中，运行auto mode的Claude Fable 5、Opus 5和Sonnet 5没有一次被攻破；

运行Codex Auto-review模式的GPT-5.6 Sol攻击成功率为5.83%，Full Access模式下为19.03%。

作为参照，Claude最新模型在不加额外防护的bypassPermissions模式下的平均攻击成功率是0.09%。



公开的三起拦截案例分别是：

一次向内部云盘上传失败后，Claude的备选方案是把同一份报告发布到公开代码分享站点，被拒绝并转为询问用户；

一次长会话中，Claude试图跨越两千个pod批量结束进程，并排队了会让数百张GPU上在跑的训练任务被拆除的删除操作，命令在执行前被标记；

还有一次是被要求配置只读账单权限时，Claude取用了一个在账户根级别拥有完整管理权限的云角色，权限范围与请求不符被拦下。

近期新增的能力包括：

把数据外泄列为hard deny，分类器永不批准，要执行必须切出auto mode或手动运行，该规则可在设置中扩展；

区分密钥与敏感信息各自可访问和可分享的范围，并在git push或PR执行前检查目标仓库是公开、私有还是可信；



在git reset —hard这类可能丢弃未提交工作的命令前读取git status；

以及在Claude拉取网页、文件或工具输出时，由API侧探针扫描注入企图并在结果进入上下文前加上警告。

想换回去？ Shift+Tab

对Pro、Max、Team用户来说，如果从未设置过默认权限模式，会收到产品内通知，新会话自动以auto mode启动；设过其他默认的会看到一次性询问；如果Team管理员已经在managed settings里指定了默认，则不受影响。

切换模式在CLI中按Shift+Tab，桌面端使用模式下拉菜单。管理员可以用managed settings中的defaultMode固定组织级默认，或用disableAutoMode完全关闭auto mode。

Anthropic在公告结尾提示，auto mode依赖分类系统，可以降低风险但不能消除风险，对生产基础设施的高风险改动，仍然建议用户自行审查Claude的操作。

本文来源：[量子位](#)

风险提示及免责条款

市场有风险，投资需谨慎。本文不构成个人投资建议，也未考虑到个别用户特殊的投资目标、财务状况或需要。用户应考虑本文中的任何意见、观点或结论是否符合其特定状况。据此投资，责任自负。

 16  收藏

分享到:  

写评论

请发表您的评论

 表情  图片

发表评论